

UNIVERSITATEA TEHNICĂ "GHEORGHE ASACHI" DIN IAȘI

FACULTATEA DE AUTOMATICĂ ȘI CALCULATOARE

MASTER: SECURITATEA SPAȚIULUI CIBERNETIC

Protocol de autentificare OAuth cu Schnorr ZKP: Securitate fără partajare de secrete

Autor: Matei Rareș

Coordonator: Ș.I.dr.inf. Silviu-Dumitru Pavăl

CUPRINS

Introducere

Tehnologii

Arhitectură

Schema Schnorr interactiva

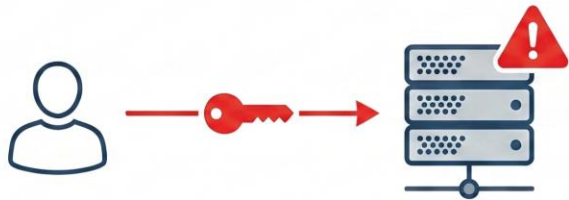
Inregistrarea & Autentificare

Validare si rezultate

Concluzii

Bibliografie

INTRODUCERE



Autentificarea OAuth clasică: secret partajat transmis către server



HTTPS: reduce interceptarea, nu elimină vulnerabilitățile structurale (breșe DB, reutilizare parole, SSDL)



Soluție: Protocol de autentificare fără transmiterea parolei către server, Schnorr

Formular pentru aplicații web

Referință cu OAuth protocoale ZKP (SRP-6a, zk-SNARK)

TEHNOLOGII



Javascript, HTML, CSS

Compatibilitate si
standardizare



Python (Flask, Locust)

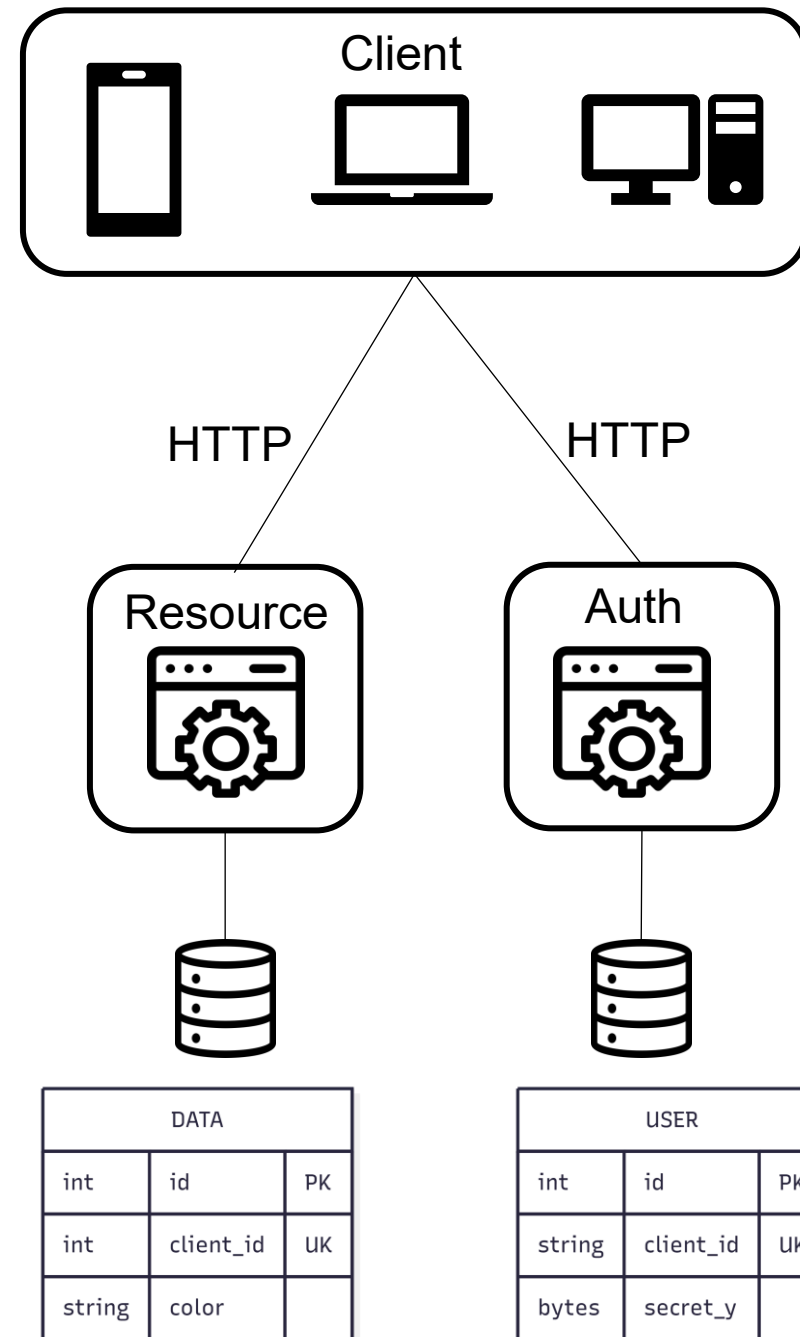
Limbaj flexibil pentru
îmbinarea mai multor
biblioteci

ARHITECTURA

Prezentare: interfață web statică,
calculare ZKP locale

Aplicație: validare/autentificare user,
emitere JWT, session binding

Date: User, Token, Personalized Data



Schnorr interactiv

Parametrii:

P - numar prim mare

Q - factor prim mare al lui P-1

G - generator unde $G \in (1, P-1)$, $h \in (1, P-1)$

a.î. $G \equiv h^{(P-1)/Q} \pmod{P}$ și $G^Q \equiv 1 \pmod{P}$

x, r, c - aleatoriu din Z_Q^*

Problema logaritmului discret (DLP)

1. Cheie: $y = G^x \pmod{P}$

2. Angajament: $t = G^r \pmod{P}$

3. Provocare: c

4. Răspuns: $s = (r + c * x) \pmod{Q}$

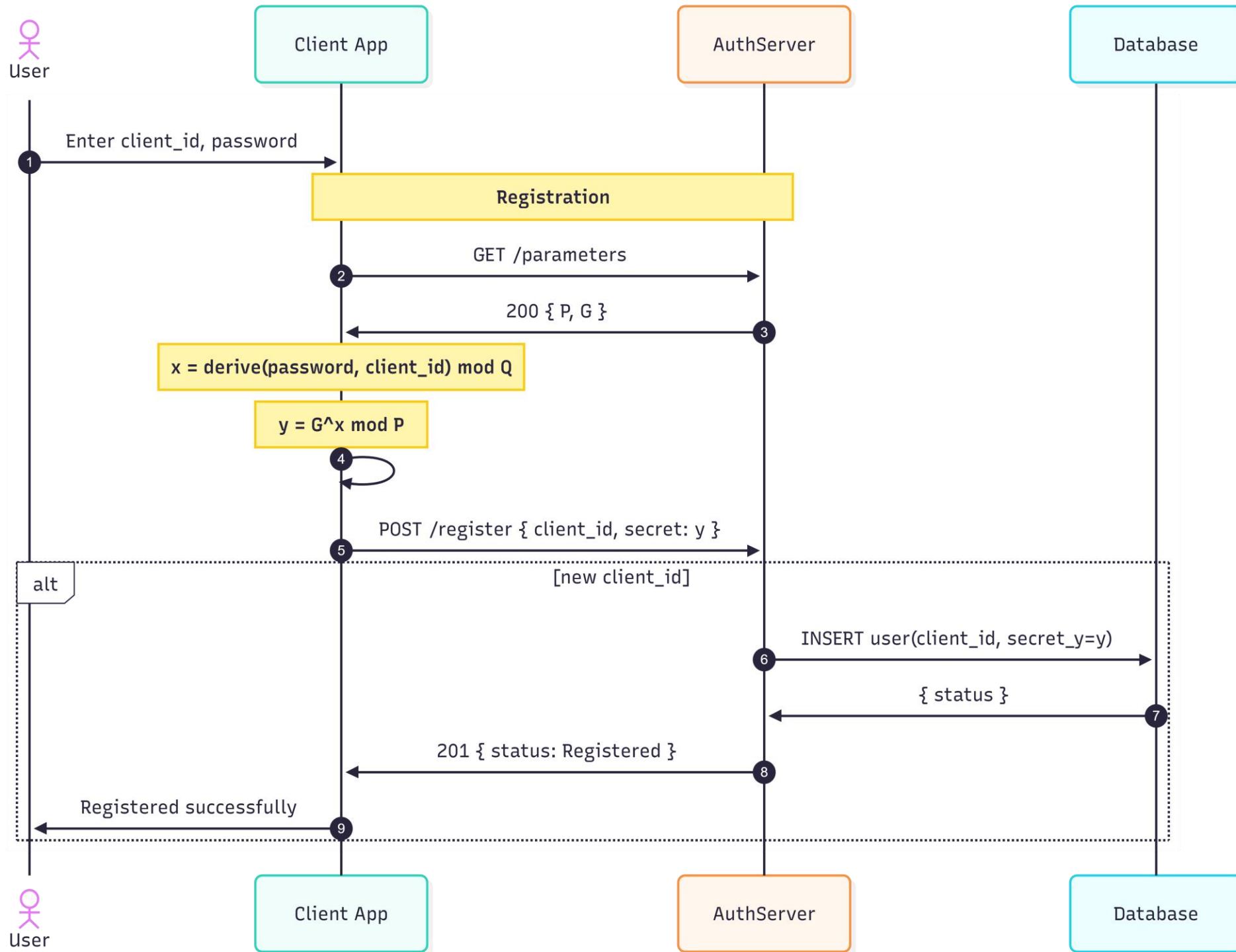
5. Verificare: $G^s \equiv t * y^c \pmod{P}$

Inregistrarea

User: introduce credențiale

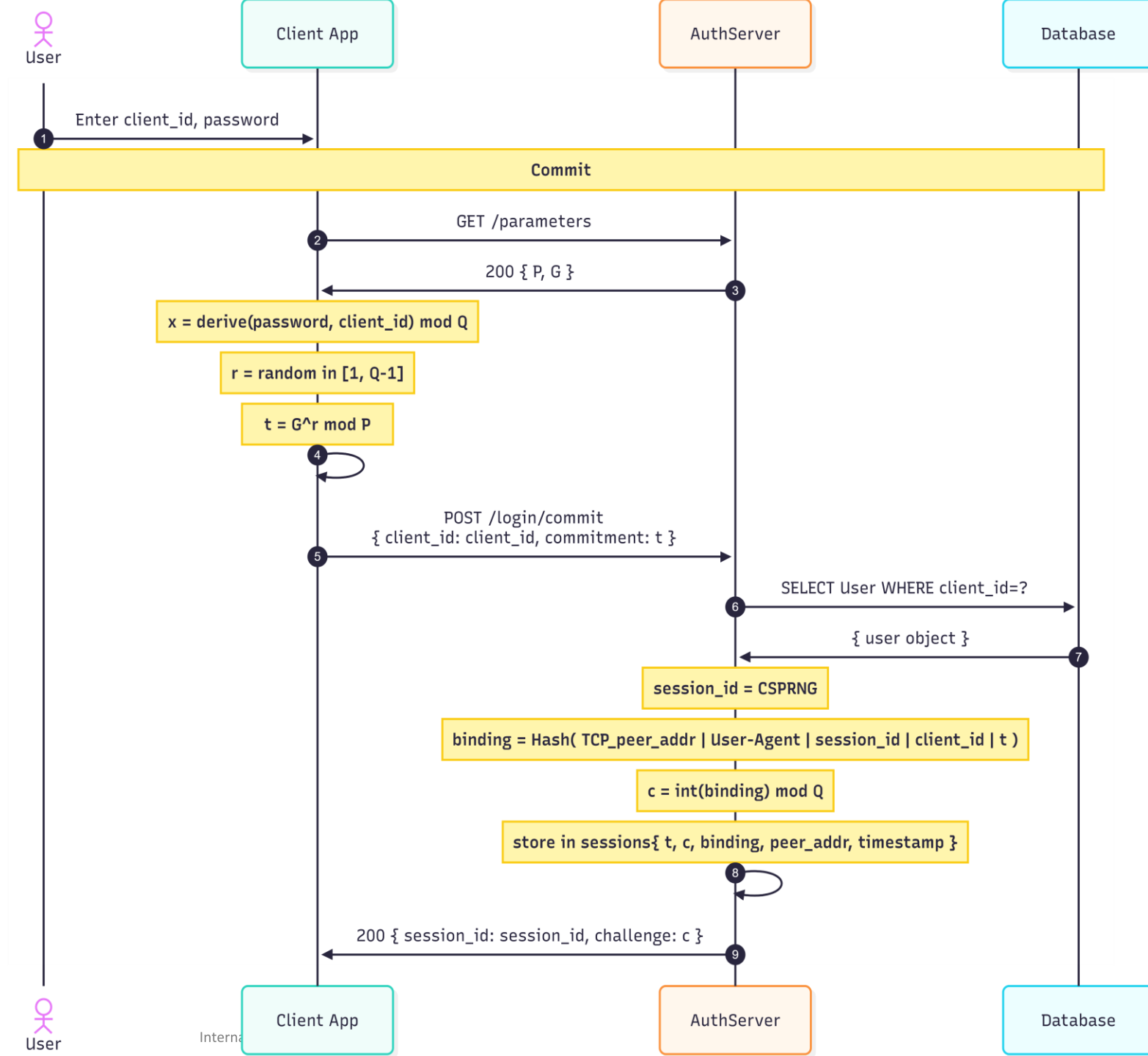
Client App: derivare x folosind parola, calculeaza y trimis la server

Server: verificare si salvare



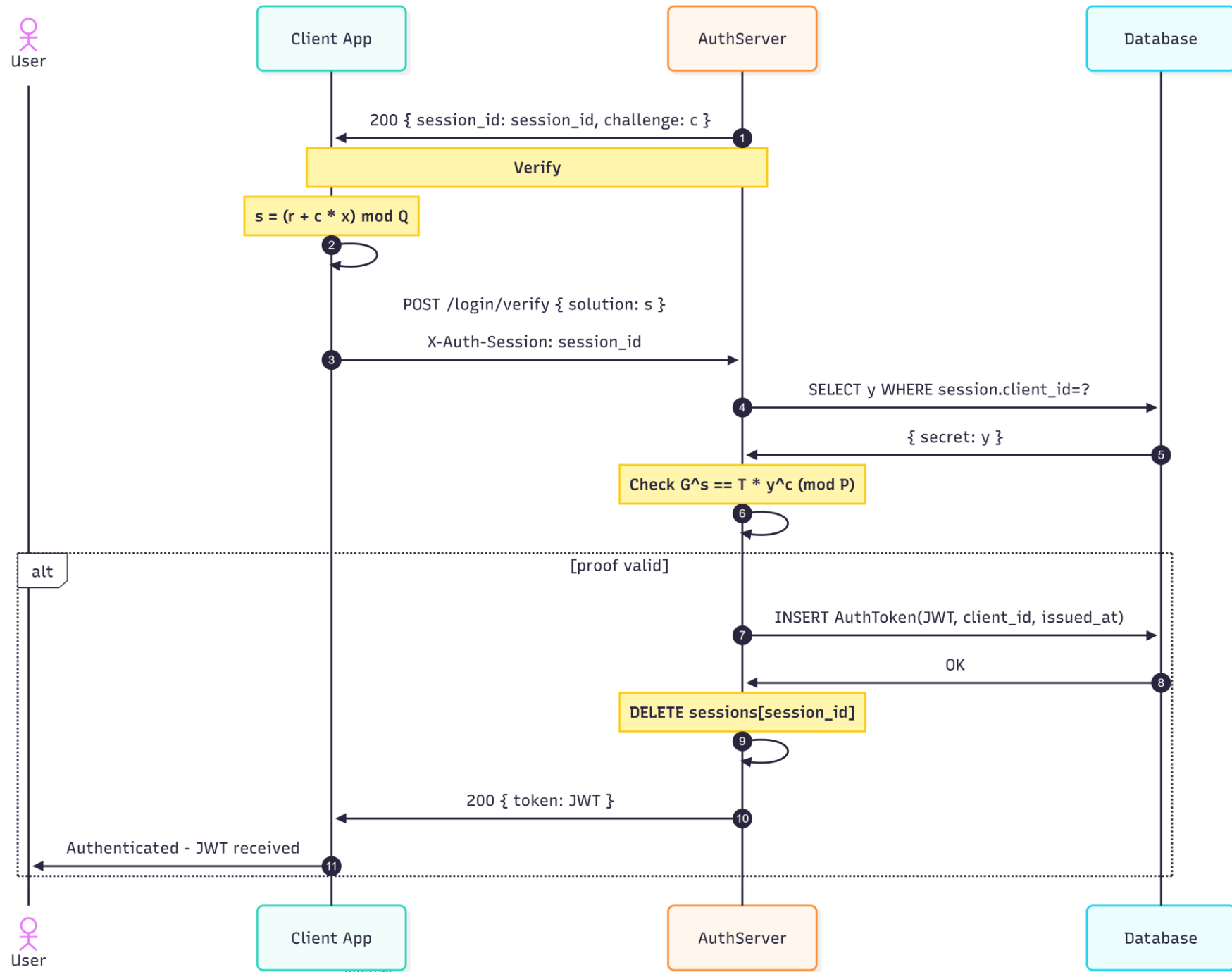
Autentificare commit

User: introduce credențiale
Client App: trimite
angajament
Server: verifica, creeaza
sesiunea, raspunde cu
provocarea

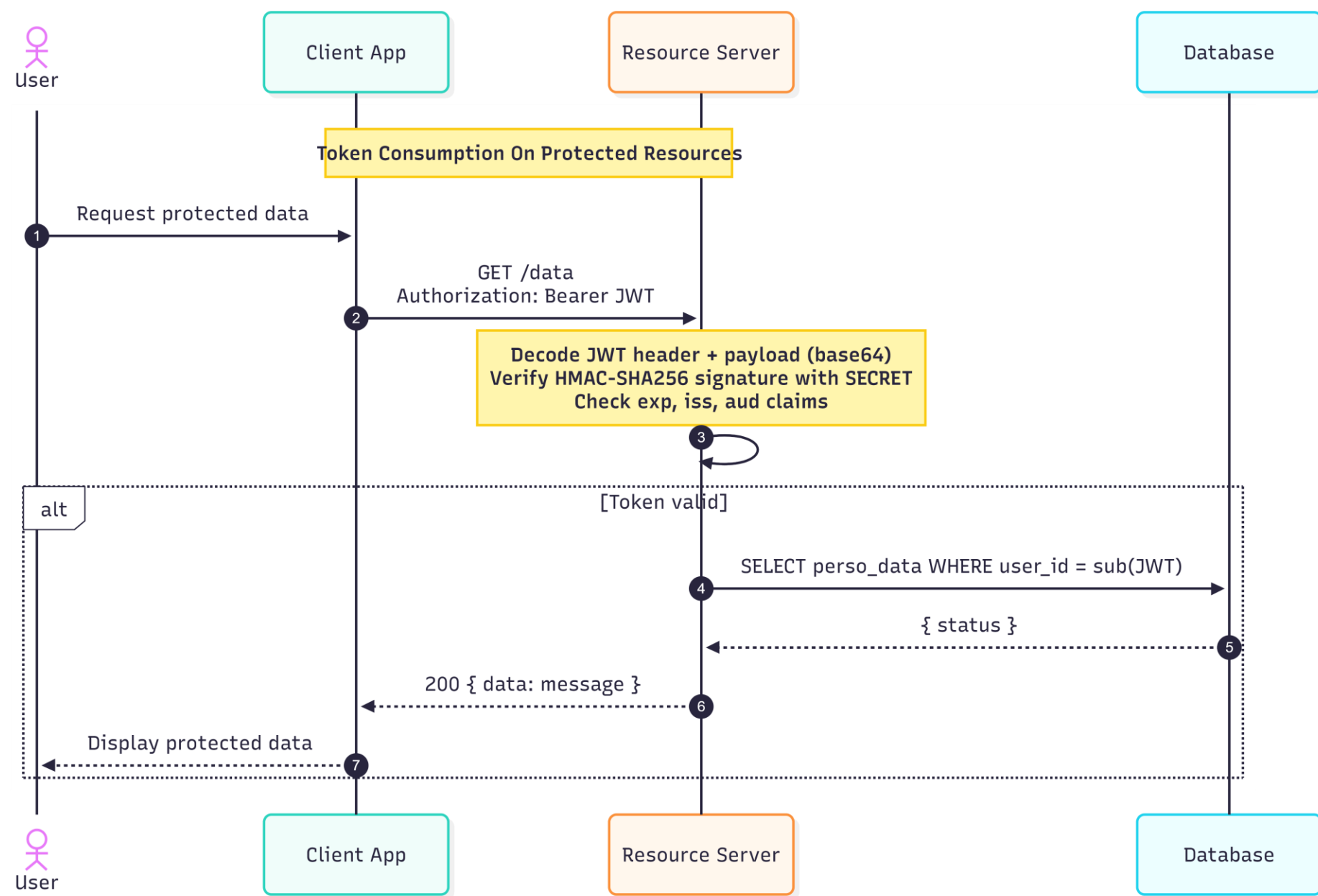


Autentificare verify

Client App:
calculeaza solutia
Server: verifica,
valideaza solutia,
returneaza token



Consum token



Proprietăți de securitate

No.	Time	Source	Destination	Protocol	Length	Info
...	9.883685800	127.0.0.1	127.0.0.1	HTTP	537	OPTIONS /parameters HTTP/1.1
...	9.887015100	127.0.0.1	127.0.0.1	HTTP	864	HTTP/1.1 200 OK
...	10.150213900	127.0.0.1	127.0.0.1	HTTP	660	GET /parameters HTTP/1.1
...	10.152405500	127.0.0.1	127.0.0.1	HTTP/J...	225	HTTP/1.1 200 OK , JSON (application/json)
...	10.200326300	127.0.0.1	127.0.0.1	HTTP	553	OPTIONS /login/commit HTTP/1.1
...	10.201559900	127.0.0.1	127.0.0.1	HTTP	873	HTTP/1.1 200 OK
+	10.468373500	127.0.0.1	127.0.0.1	HTTP/J...	888	POST /login/commit HTTP/1.1 , JSON (application/json)
+	10.477661700	127.0.0.1	127.0.0.1	HTTP/J...	208	HTTP/1.1 200 OK , JSON (application/json)
...	10.517033600	127.0.0.1	127.0.0.1	HTTP	568	OPTIONS /login/verify HTTP/1.1
...	10.518286600	127.0.0.1	127.0.0.1	HTTP	889	HTTP/1.1 200 OK

Frame 431: 888 bytes on wire (7104 bits), 888 bytes captured (7104 bits) on interface \Device\NPF_{Loopback}, id 0

Null/Loopback

Internet Protocol Version 4, Src: 127.0.0.1, Dst: 127.0.0.1

Transmission Control Protocol, Src Port: 55402, Dst Port: 5000, Seq: 1, Ack: 1, Len: 844

Hypertext Transfer Protocol

JavaScript Object Notation: application/json

Object

- Member: client_id
 - [Path with value: /client_id:a]
 - [Member with value: client_id:a]
 - String value: a
 - Key: client_id
 - [Path: /client_id]
- Member: commitment_t
 - [Path with value: /commitment_t:609542982768614174169120491451124030472011456449342921440365914701509638117288019943907611886196225350492]
 - [Member with value: commitment_t:609542982768614174169120491451124030472011456449342921440365914701509638117288019943907611886196225350492]
 - String value: 609542982768614174169120491451124030472011456449342921440365914701509638117288019943907611886196225350492
 - Key: commitment_t
 - [Path: /commitment_t]

Server stocheaza doar y - data breach (DLP)

{t, c, s} efemere - replay

r si x netransmise - interceptare, SNDL (DLP)

Validare si testare

49 teste pytest, 100% succes

CATEGORIE TESTE	NR.	ACOPERIRE
Pozitive	5	Happy paths, lipsa parola DB, useri concurenti
Negative	5	Parolă greșită, c duplicat, expirare sesiune, commit dublu, înregistrare duplicate
Corner case	31	$s \notin Z_Q^*$, $y/t \in \{0,1,-1,P-1\}$, tipuri neconforme (float/string/null), lipsa header
Securitate	8	off-by-one, sesiuni izolate, y furat

SIMULARI	REZULTAT
Coliziune in 10.000 cereri	0 coliziuni c
MitM parametri slabi: P=23, Q=11, G=4	HTTP 422: y/t respinse (subgrup invalid)
Replay cross-sesiune	HTTP 401: $G^{s1} \neq t2 * y^{c2}$

BRUTE FORCE DLP	CANDIDATI	REZULTAT
32 biți	$\sim 1,07 * 10^9$	744M încercări (319s)
64 biți	$\sim 4,6 * 10^{18}$	Timeout 1200s
2048 biți	$\sim 5,87 * 10^{153}$	Nefezabil

Evaluare performanta

P de 2048 biti
(recomandare NIST)

OPERAȚIE	MEDIE (MS)	MIN (MS)	MAX (MS)	STDDEV (MS)
$y = G^x \bmod P$	15.65	14.37	19.86	1.06
Generare solutie: (s)	0.009	0.009	0.01	0.0003
Validare apartenență subgrup	17.15	15.74	19.89	0.96
Legare de sesiune	0.002	0.002	0.020	0.001
Generare provocare (c)	0.001	0.0009	0.001	0.0003
$G^s \equiv t * y^c \pmod{P}$	33.87	31.68	37.7	1.31

Evaluare performanta

USERI	SCHNORR POW (RPS)	PKCE (RPS)	SIMPLE (RPS)	AUTHLIB (RPS)
10	19,61	464,82	440,26	489,10
50	18,10	465,68	463,45	481,65
100	17,47	458,06	467,56	505,24

Debit concurent (Locust, 8 fire, 60s)

E2E pe 100 iteratii secventiale

PROTOCOL	MEDIE (MS)	MIN(MS)	MAX (MS)	P95 (MS)
Schnorr Pow (commit + verify)	64,76	59,24	85,98	78,71
OAuth2 PKCE	2,23	1,81	22,21	1,58
OAuth2 Simple	2,19	1,82	14,23	2,72
Authlib PKCE	0,79	0,71	1,68	0,95

Evaluare performanta

100 iteratii secventiale

PROTOCOL	ÎNREG. (MS)	AUTENTIF. (MS)	TOTAL (MS)
Schnorr-Pow	15,783	139,833	155,911
SRP	1,204	41,061	42,265
Schnorr-EC	4,005	34,093	38,090
Schnorr-EC-C-Lib	0,071	9,447	9,510

Concluzii

- Se poate folosi Schnorr intr-un protocol de tip Open Authorization, reducand expunerea crențialelor
- O implementare ZKP anulează o breșă a bazei de date, sau o exfiltrare a datelor prin folosirea de valori efemere
- Limitări: latența, lipsă verificare browser
- Potential de dezvoltare prin folosirea EC, C sau adaugarea altor metode de intarire a securitatii precum PQC si OAuth2.0+Schnorr

Bibliografie Selectivă

- [9] S. Goldwasser, S. Micali, C. Rackoff, "The Knowledge Complexity of Interactive Proof Systems," SIAM J. Computing, 1989.
- [16] C.P. Schnorr, "Efficient Signature Generation by Smart Cards," J. Cryptology, 1991.

VĂ MULȚUMESC
PENTRU ATENȚIE!
